Classification DICT des applications PEUCIT

Standard technique de sécurité des SI : applications n° 1, 3, 4, 7 et 10

GROUPE 1

Arthur Poncin · Nathan Chevaudra · Amen Ahouandogbo · Habibou Halirou · Jihad Mabsout

TP 3 · Stratégie des risques IT · EPSI M1

Contexte et mission

PEUCIT

- Constructeur automobile, 260 000 personnes
- 154 Md€ de CA, 6,5 M de véhicules par an
- Environ 3 000 applications

Les constats de la DSI

- Des applications mal protégées
- Des investissements cyber décorrélés de la criticité métier
- Des PRA à prioriser

Notre mission

Noter de 1 à 3 nos 5 applications sur les 4 critères DICT, en justifiant chaque note.

Pour permettre ensuite de

- Prioriser les PCA/PRA
- Adapter les mesures de cybersécurité
- Hiérarchiser les investissements
- Repérer les applications à surveiller de près

Notre grille de notation

Note	D : arrêt supportable	I : remise en état	C : divulgation	T : besoin de preuve
1 : Faible	Plus de 48 h	Corrigée tout de suite	Impact faible, sans préjudice durable	Journaux techniques suffisants
2 : Moyenne	Entre 12 h et 48 h	Restauration depuis une sauvegarde	Atteinte ponctuelle à l'image	Historique utile (audit, litige)
3 : Forte	Moins de 12 h	Jours de correction, pertes, sécurité	Patrimoine, confiance, données sensibles	Preuve exigée : réglementation, fraude

Trois règles appliquées

1. **Données personnelles** : au minimum I = 3, C = 3 et T = 2.
2. **Disponibilité variable** : on retient la période critique (paie, clôture, campagne).
3. **On note le besoin, pas l'existant** : datacenters redondés et sauvegardes ne font pas baisser les notes.

N° 1 · PAYEX

Paie France

UTILISATEURS

34 : gestionnaires RH, responsables, administrateurs

DONNÉES

- Identité, adresse, RIB
- Salaires, primes
- Sanctions, arrêts maladie
- Données fiscales

USAGE

Toute l'année, vital les 5 derniers jours ouvrés du mois

BULLETIN DE PAIE · OCTOBRE

Salaire de base	2 450,00 €
Cotisations	- 540,00 €
Net à payer	**191 000,00 €**

Le salarié est ravi. La DRH, beaucoup moins.

D 3 Plusieurs jours d'arrêt en fin de mois = **pas de salaires versés**. Hypothèse : les virements partent avant le jour de paie, la marge réelle tombe **sous 12 h**. Hors paie : 2.

I 3 Un salaire modifié par erreur : erreurs de paiement, rappels, **conflits sociaux**, régularisations RH et compta.

C 3 RIB, salaires, arrêts maladie : **données de santé**, donc sensibles au sens du RGPD et protégées en priorité.

T 3 Historique complet obligatoire, **chaque changement de salaire doit être justifié**.

N° 3 · PRODLINE

UTILISATEURS

1 390 : opérateurs, chefs d'équipe, responsables

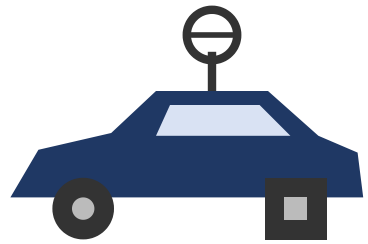
USAGE

24h/24, 6 j/7, 900 véhicules par jour

D	3	Au-delà de **10 minutes**, les lignes s'arrêtent. Plus de **300 000 € par heure**.
I	3	Une mauvaise nomenclature = une mauvaise pièce sur des centaines de véhicules : **rappels massifs** et risque pour la sécurité des clients.
C	2	Savoir-faire industriel, mais **partagé par 1 400 personnes** et sans données personnelles. Le vrai danger, c'est l'arrêt ou le sabotage, pas la fuite.
T	3	Chaque véhicule doit rester **traçable plus de 15 ans** (VIN, pièces montées) pour cibler les rappels. Normes CO2 européennes.

Résultat : la même erreur sur **900 véhicules par jour**, puis un rappel massif. **I = 3**

Robot de montage
nomenclature v2.3 ⚠



N° 4 · ASSET

UTILISATEURS

300 à la Direction financière

DONNÉES

- 250 000 biens
- Valeurs d'achat, amortissements
- Localisation, n° d'inventaire

USAGE

Jours ouvrés, de 7 h à 22 h en clôture. Batch mensuel

MER

ASSET en panne depuis 3 jours

zzz



Hors clôture, personne n'a remarqué.

D 2

Hors clôture, **plusieurs jours d'arrêt acceptables** (1). En clôture, plus d'une journée retarde les comptes (2). On retient la clôture.

I 2

Une erreur fausse les états financiers, **sans effet sur la production**. Les amortissements se recalculent.

C 1

Pas de données personnelles. Les valeurs sont déjà **publiées dans les comptes annuels**.

T 2

Les commissaires aux comptes contrôlent les entrées et les mises au rebut. Une **mise au rebut fictive** peut masquer un vol.

N° 7 · TALENT

Entretiens annuels et objectifs

UTILISATEURS

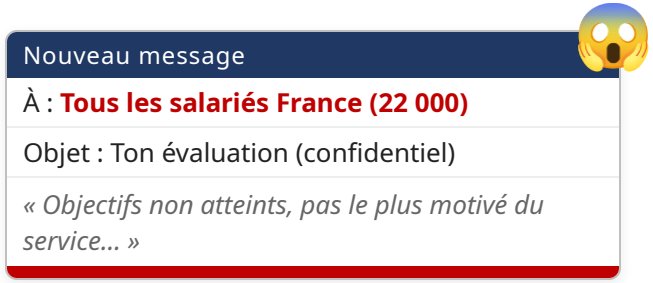
22 000 salariés, 3 000 managers, 80 gestionnaires RH

DONNÉES

- Évaluations, commentaires
- Objectifs, compétences
- Souhaits et pronostics de carrière

USAGE

Campagnes en déc.-janv. et en juin



Un clic sur « Répondre à tous ».

D 2

Une campagne dure des semaines : quelques heures d'arrêt se rattrapent. **Au-delà de 48 h en campagne**, les entretiens glissent (hors campagne : 1).

I 3

Une évaluation modifiée à tort **pénalise un salarié**, fausse une augmentation, déclenche un conflit.

C 3

Appréciations hiérarchiques, pronostics de carrière : **parmi les données RH les plus sensibles**, confidentielles par nature.

T 3

25 000 utilisateurs : il faut savoir **qui a lu l'évaluation de qui**, et prouver les modifications en cas de litige.

N° 10 · QUALITYDOC

Plateforme documentaire

UTILISATEURS

Environ 8 000 (qualité, IT, RH, achats…)

DOCUMENTS

- Normes qualité, certifications
- Dossiers d'architecture IT
- Comptes rendus, formations

USAGE

Jours ouvrés

Droits : tout le monde



D 1 — **Aucun processus ne s'arrête** sans elle, les documents courants peuvent vivre ailleurs.

I 3 — Elle stocke des **documents RH, donc des données personnelles** : I au minimum 3. Un mauvais document peut aussi fausser une décision.

C 3 — C'est **le coffre recommandé pour les documents sensibles**. Dossiers d'architecture IT = carte au trésor pour un attaquant.

T 2 — Le circuit de validation sert de **preuve lors des audits qualité**. Pas d'exigence réglementaire forte.

« Sauvegardée et redondée » : c'est une mesure existante, elle ne fait pas baisser la note.

Synthèse

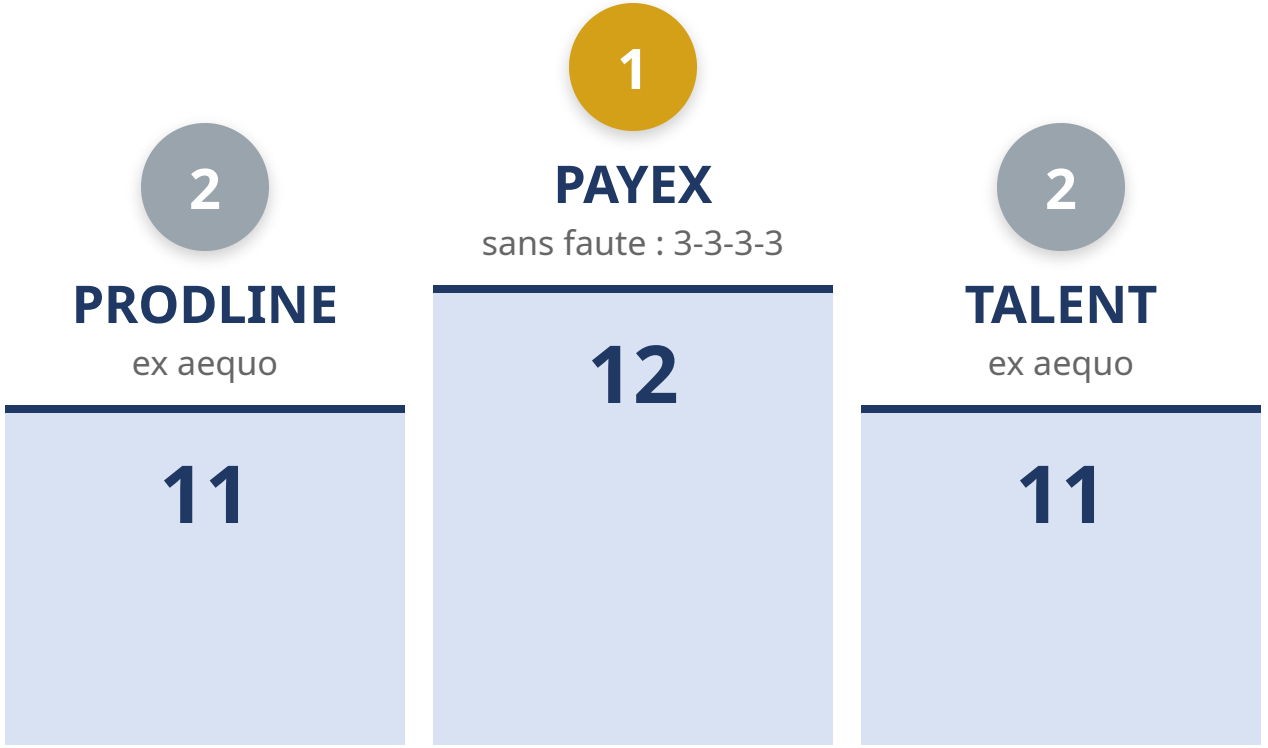
Application	D	I	C	T	Total /12
PAYEX	3	3	3	3	12
PRODLINE	3	3	2	3	11
TALENT	2	3	3	3	11
QUALITYDOC	1	3	3	2	9
ASSET	2	2	1	2	7

Les deux applications **RH** sont au maximum en confidentialité et en traçabilité.

PRODLINE est la seule où une panne se compte en minutes.

Le classement

Total DICT sur 12



4e · QUALITYDOC
9 / 12, sauvée par ses documents sensibles

ASSET · 7 / 12
Prix spécial de la sérénité.
Plusieurs jours de panne ?
Même pas mal.

Mais pour le PRA, l'ordre change : **PRODLINE passe en premier**. Le total ne fait pas tout.

Ce que la classification change

Usage	Critère lu	Décision
Priorité PRA	D	1. PRODLINE (bascule quasi immédiate) · 2. PAYEX (PRA testé avant chaque fin de mois) · 3. TALENT et ASSET (48 h en période critique) · 4. QUALITYDOC
Mesures cyber	C et I	PAYEX, TALENT : chiffrement, accès au strict besoin, revue des habilitations. PRODLINE : réseau industriel isolé, contrôle des changements de nomenclature. QUALITYDOC : droits par document
Investissements	Les 4	D'abord PRODLINE, puis PAYEX et TALENT, puis QUALITYDOC. ASSET reste sur le socle commun du groupe
Surveillance renforcée	T = 3	PAYEX, PRODLINE, TALENT : alertes sur les changements de RIB ou de salaire, les consultations massives d'évaluations, les nomenclatures modifiées hors processus

Conclusion

- 3 applications sur 5 atteignent le niveau maximal sur au moins trois critères.
- Les applications **RH** sont critiques pour la **confidentialité**, **PRODLINE** pour la **disponibilité**.
- On note le besoin, pas les protections déjà en place : c'est ce qui permet ensuite de mesurer l'écart.
- Le total aide à se repérer, mais chaque décision se lit sur un critère précis.

Merci de votre attention. Des questions ?